



Universidad Veracruzana

Facultad de Estadística e Informática

Región: Xalapa

Licenciatura en Ingeniería en Ciberseguridad e Infraestructura de Computo

Estado del arte de las medidas de seguridad a nivel de aplicación en el contexto de ataques de inyección de *prompt* dirigidos a sistemas basados en LLM

Presentación de avances para la EE Proyecto Guiado

Presenta:

Abraham Núñez Sánchez

Presenta:

Héctor Xavier Limón Riaño

Septiembre 2026

“Lis de Veracruz: Arte, Ciencia, Luz”

Antecedentes (I/4) - Contexto

- La ciberseguridad busca proteger la información y los sistemas frente a amenazas y ataques.
- La IA generativa, particularmente los modelos grandes de lenguaje (LLM), se ha incorporado en aplicaciones y servicios digitales.
- Los sistemas basados en LLM pueden integrar:
 - *Prompts* e instrucciones.
 - Entradas de usuarios.
 - Documentos y fuentes externas.
 - Herramientas y APIs.

Su uso se extiende a generación de contenido, análisis de información, programación, automatización y ciberseguridad.

Antecedentes (2/4) – *Prompt Injection*

- Los ataques de *prompt injection* explotan la forma en que los sistemas procesan instrucciones y datos dentro de un mismo contexto.
- Se distinguen principalmente:
 - Inyección directa: el atacante introduce directamente instrucciones maliciosas mediante la entrada al sistema.
 - Inyección indirecta: las instrucciones maliciosas provienen de recursos externos, como documentos o páginas web.

Antecedentes (3/4) – *Prompt Injection*

- Una inyección puede provocar:
 - Alteración del comportamiento del sistema.
 - Revelación de información.
 - Incumplimiento de instrucciones.
 - Ejecución de acciones no previstas.

Antecedentes (4/4) – Medidas a nivel de aplicación

Las medidas de seguridad a nivel de aplicación:

- Actúan sobre la aplicación o plataforma que integra al LLM.
- No requieren modificar el entrenamiento ni la arquitectura interna del modelo.

Ejemplos:

- Procesamiento y filtrado de entradas.
- Detección de contenido malicioso.
- Validación de salidas.
- Monitoreo y registro.

Problemática (I/2)

Los sistemas basados en LLM pueden combinar instrucciones confiables y entradas no confiables dentro de un mismo contexto.

Esto permite que contenido manipulado por un atacante influya en el comportamiento del sistema.

Se han propuesto diversas medidas de defensa, pero:

- Actúan en diferentes componentes y etapas.
- Utilizan mecanismos distintos.
- Son evaluadas bajo diferentes escenarios y criterios.

Problemática (I/2)

Las defensas pueden presentar compromisos entre:

- Seguridad.
- Utilidad.
- Rendimiento.
- Costo.
- Latencia.

El conocimiento sobre las medidas de seguridad frente a *prompt injection* se encuentra disperso, particularmente en aquellas que pueden implementarse a nivel de aplicación.

Preguntas de investigación (1/2) – Pregunta principal

- ¿Qué medidas de seguridad a nivel de aplicación han sido propuestas y evaluadas frente a los ataques de inyección de *prompt* en sistemas basados en LLM, y cuáles son sus principales características, alcances, limitaciones y criterios de evaluación?

Preguntas de investigación (2/3) – Preguntas complementarias

- ¿Qué es un ataque de inyección de *prompt* y cuáles son las categorías que presenta?
- ¿Qué medidas de seguridad a nivel de aplicación han sido propuestas en la literatura reciente para reducir los ataques de inyección de *prompt* en sistemas basados en LLM?
- ¿Cómo pueden clasificarse las medidas de seguridad identificadas de acuerdo con el punto de intervención dentro del sistema basado en LLM?

Preguntas de investigación (3/3) – Preguntas complementarias

- ¿En qué contextos y escenarios han sido evaluadas las medidas identificadas, qué tipos de ataques abordan y qué criterios se utilizan para determinar su efectividad?
- ¿Qué limitaciones y compromisos entre seguridad, utilidad, rendimiento, costo o complejidad de implementación han sido reportados para las medidas analizadas?
- ¿Qué cosas permanecen abiertas o insuficientemente en la literatura sobre medidas de seguridad a nivel de aplicación frente a ataques de inyección de *prompt*?

Objetivos (1/2) - Objetivo general

- Analizar las medidas de seguridad a nivel de aplicación frente a ataques de inyección de *prompt* en sistemas basados en LLM, mediante la revisión, clasificación, comparación y síntesis de literatura científica reciente, con el propósito de identificar sus características, contextos de aplicación, alcances, limitaciones y criterios de evaluación.

Objetivos (2/3) - Objetivos específicos

- OE-01: Identificar los ataques de inyección de *prompt* que pueden ser mitigados desde el lado de la aplicación.
- OE-02: Analizar las medidas de seguridad a nivel de aplicación propuestas en la literatura reciente para mitigar los ataques de inyección de *prompt* en sistemas basados en LLM.
- OE-03: Clasificar las medidas de seguridad identificadas de acuerdo con el punto de intervención dentro del sistema.

Objetivos (3/3) - Objetivos específicos

- OE-04: Identificar las taxonomías existentes para clasificar las mitigaciones de ataques de inyección de *prompt* a nivel de aplicación.
- OE-05: Analizar las formas en las que se evalúan las medidas de seguridad reportadas en la literatura considerando los tipos de ataques abordados, contextos de aplicación, criterios de evaluación, efectividad, impacto sobre la utilidad y limitaciones.
- OE-06: Discutir los alcances y limitaciones que permanezcan abiertos para futuras investigaciones.

Justificación (I/2) - Situación actual y necesidad

- Los ataques de *prompt injection* han sido identificados en diferentes escenarios.
- Existe una diversidad de medidas de seguridad propuestas.
- Las medidas presentan diferentes alcances, limitaciones y criterios de evaluación.
- La información disponible se encuentra distribuida.
- No existe una visión organizada específicamente de las medidas implementables a nivel de aplicación.

Justificación (2/2) – Aporte esperado

- Identificar las medidas existentes.
- Clasificarlas según su punto de intervención.
- Comparar y sintetizar sus características.
- Analizar:
 - Contextos de aplicación.
 - Criterios de evaluación.
 - Alcances y limitaciones.
 - Compromisos entre seguridad y utilidad.
- Identificar aspectos abiertos para futuras investigaciones

Delimitación del trabajo

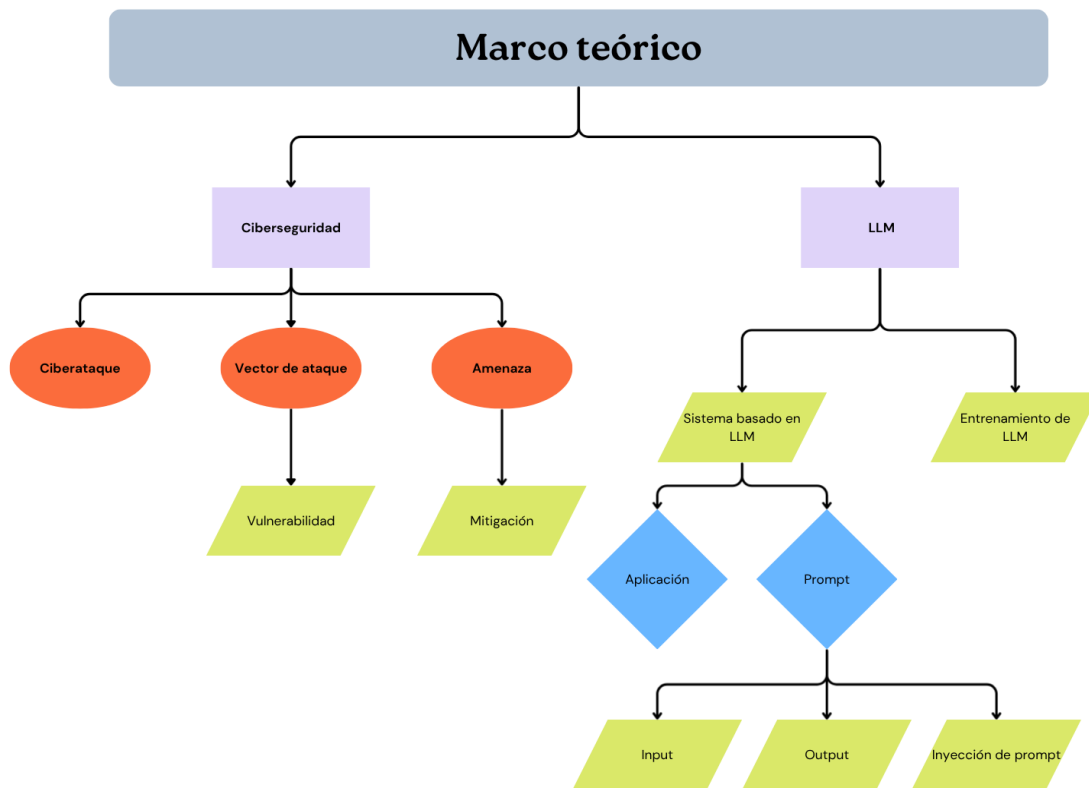
Alcances

- Alcance de tipo descriptivo.
- Literatura científica no mayor a cinco años en ingles.
- Literatura que sea accesible mediante motores de búsqueda con acceso institucional como ACM, *Springer*, *ScienceDirect* e IEEE.
- Centrada en el área de ciberseguridad analizando los ataques y mitigaciones.
- Medidas de seguridad que pueden implementarse a nivel de aplicación.

Limitaciones

- Artículos o revisiones que no puedan ser accedidos por medios institucionales.
- Artículos o revisiones que no hayan sido publicados o revisados oficialmente.
- Medidas de seguridad que modifiquen el LLM.

Marco teórico del trabajo

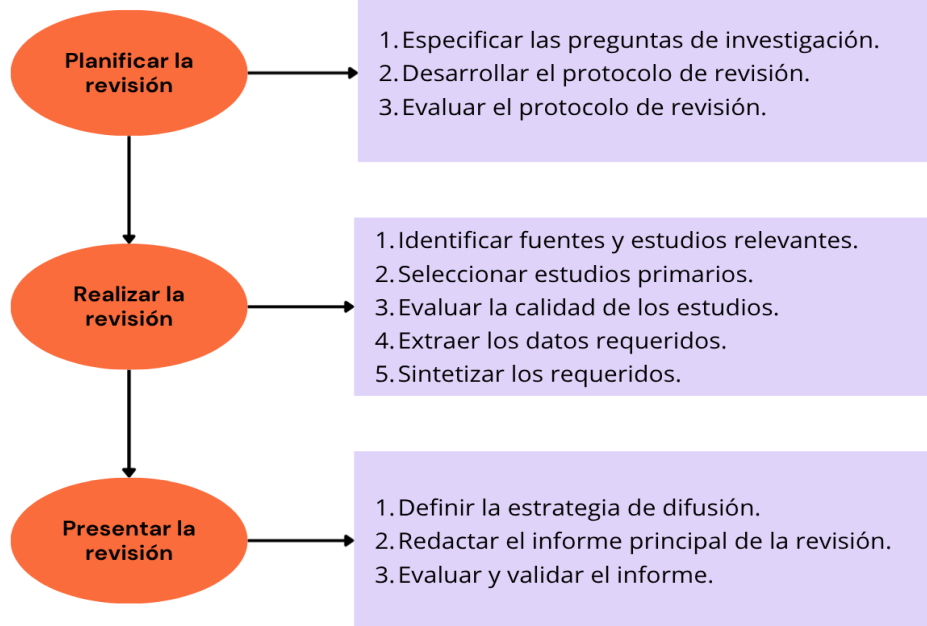


Método de investigación - Kitchenham

- Es un marco para realizar revisiones sistemáticas de literatura especializado en la ingeniería de software
- Busca minimizar el sesgo mediante protocolo definidos, estrategias de búsqueda auditables y criterios estrictos de inclusión de estudios.
- Kitchenham define la revisión sistemática de literatura como una forma de identificar, evaluar e interpretar la mayor cantidad de información disponible y relevante sobre un tema.
- Una revisión sistemática es un estudio secundario mientras que los estudios individuales que contribuyen a la revisión son estudios primarios.

Método de investigación – Etapas del método Kitchenham

Fases del metodo de Kitchenham



Estructura del trabajo recepcional

1. Introducción
 - 1.1. Antecedentes
 - 1.2. Definición del problema
 - 1.3. Objetivos
 - 1.3.1. Objetivo general
 - 1.3.2. Objetivos específicos
 - 1.4. Justificación
 - 1.5. Delimitación del proyecto
 - 1.5.1. Alcance
 - 1.5.2. Limitación
 2. Marco teórico
 - 2.1. Ciberseguridad
 - 2.1.1. Ciberataque
 - 2.1.1.1. Vector de ataque
 - 2.1.1.2. Vulnerabilidad
 - 2.1.1.3. Amenaza
 - 2.1.1.4. Mitigación
 - 2.2. LLM
 - 2.2.1. Sistema basado en LLM
 - 2.2.1.1. Aplicación basada en LLM's
 - 2.2.1.2. *Prompt*
 - 2.2.2. Entrenamiento de LLM
3. Método de investigación
4. Resultados
 - 4.1. Cuantitativos
 - 4.2. Cualitativos
5. Discusión
6. Amenazas a la validez
7. Conclusiones y trabajo futuro

Cronograma

Actividades	Meses																
	2026					2027											
	Agosto	Septiembre	Octubre	Noviembre	Diciembre	Enero	Febrero	Marzo	Abril	Mayo	Junio	Julio	Agosto	Septiembre	Octubre	Noviembre	Diciembre
Protocolo de investigación																	
Protocolo de la revisión																	
Selección de cadena de búsqueda																	
Selección de estudios primarios																	
Extracción de datos																	
Síntesis narrativa																	
Reporte de la revisión																	
Concentrarse en una o dos fuentes de información																	
Explorar más fuentes y snowballing																	
Ampliar selección de estudios																	
Realizar extracción de nuevos estudios																	
Realizar síntesis sistematica																	
Escribir un borrador de articulo																	
Desarrollo de marco teórico																	
Definición de la discusión																	
Definición de la conclusión																	
Trabajo futuro																	